

Auwa Privacy & Data Architecture

Created 27 May 2026. Single source of truth for what user data lives where, how it is protected, and what we commit to never doing with it. Load when the topic is privacy, data architecture, encryption, account deletion, or anything involving where the user's content sits in our infrastructure.

1. The principle

Auwa holds user data in two tiers with different protections. The line between the tiers is exactly the line of intent. Tier one is content the user chose to make and is comfortable having stored privately. Tier two is content the user took out of their head to wash. The painful content gets the strongest possible protection. Everything else gets normal good protection.

This is not just an engineering choice. It is part of the brand's defensive moat (see `business.md` Section 15) and it is part of how the brand expresses care for the user. The standard wellness app stores user content in plain text on its servers. We chose differently from day one.

2. Tier one: standard private storage

What lives here.

- Account info (email, name, password hash, subscription state)
- Daily revelations (state, sub-expression, context tap, reflection ID)
- Firefly Trove entries (the daily light answer text, the optional photo)
- Kokoro state (accumulated motifs, weather, threshold markers)
- Archive observations and pattern data
- Letters from Auwa, sound library state, sanctuary preferences

How it is stored.

- Vercel Postgres (text data) and Vercel Blob (photos)
- Encrypted at rest by the underlying infrastructure (industry standard)
- Private access controls with role-based authorisation

- Standard backups with appropriate retention
- TLS in transit for all client-server communication

What we will never do with this data.

- Sell it. Ever. No data partnerships, no marketing data brokers, no ad targeting based on user content.
- Train AI on user content. The reflection library is Rieko-authored; no user input is ever used to train a model.
- Display one user's content to another user. The Kokoro is private. The trove is private. The archive is private.
- Share with third parties beyond strict infrastructure necessity (Vercel for hosting, Stripe for payments, Resend for email). Each of these has a data processing agreement in place.

3. Tier two: end-to-end encrypted storage (Senshin only)

What lives here.

- Senshin entries: category taps, emotion taps, optional in-app two-column text, status markers (still on my mind / settled), free-text labels

How it is stored.

- Encrypted on the user's device before the data ever leaves it
- Encryption key derived from the user's password using Argon2id with appropriate parameters
- Encrypted blobs travel to Vercel Postgres; what we store is mathematically unreadable
- Libraries: libsodium-wrappers or TweetNaCl.js (industry-standard, well-audited)
- Architecture matches Signal, ProtonMail, Standard Notes, 1Password

What this means in practice.

- Auwa cannot read Senshin entries. Not now, not ever, not under subpoena, not after a breach.
- A legal request for a user's Senshin data yields encrypted blobs we cannot decrypt.
- A breach of our database yields encrypted blobs.
- A future Auwa employee with bad intentions cannot peek; the data is noise without the user's password.

The recovery key.

- Offered as an optional safeguard at signup
- A long random string generated on-device using a CSPRNG
- Shown once, with explicit acknowledgement of what losing it means
- The user saves it (print, screenshot, password manager); we never store it
- The only way to recover Senshin entries if the user forgets their password
- Without the recovery key and without the password, the entries are lost forever. This is the cost of true privacy and we communicate it clearly.

Account deletion.

- Hard-deletes encrypted Senshin blobs immediately
- No soft delete, no thirty-day retention, no backup
- Gone

Export.

- At any time from settings, the user can export the entire Senshin archive as plain text or PDF
- Export happens on-device after decryption; the decrypted content never travels off the user's device through our infrastructure

4. Crisis support

A small, persistent, never-pushy link on the Senshin entry screens at all times: *If this is heavier than the page can hold, find someone to talk to.* Tapping opens a screen listing regional crisis support services (Samaritans UK, 988 US, Lifeline Australia, TELL Japan, equivalents elsewhere), clearly framed as independent organisations not affiliated with Auwa.

- No content detection. No keyword matching. No intervention triggered by what the user wrote.
- No telemetry on whether the link was tapped.
- Always-available door, never crisis-triggered.
- List reviewed and updated quarterly, localised by user's stored locale.

Auwa never decides for the user that they need help. We make sure help is one tap away if they decide for themselves.

5. What we tell users

Privacy promises committed verbatim in the privacy policy and reinforced in the Senshin first-use intro:

- We cannot read your Senshin entries. The encryption makes this technically impossible from our side.
- Your entries are never used to train AI, classified by NLP, or analysed in any way on our side.
- Your entries are never shared with third parties for any purpose.
- If you forget your password and have no recovery key, the entries cannot be retrieved. This is the cost of true privacy.
- When you delete your account, your encrypted Senshin entries are deleted immediately.
- All other app content (reflections, fireflies, Kokoro) is stored privately, never sold, never used to train AI, and never shown to other users.

6. Internal engineering disciplines

- No analytics on Senshin content fields. Crash reports redact the Senshin schema entirely.
- No NLP, ML, or AI processing on Senshin entries on the server side. The encryption makes this technically impossible anyway, which is the point.
- No backups outside the encrypted blob form. We back up what we have, which is encrypted text we cannot read.
- Code review discipline: any change touching the Senshin storage layer requires explicit review by Tom for adherence to these principles.

7. What the user never sees

- Senshin entries on any surface other than their own private archive (never on share cards, never on social, never on any user's screen but the author's)
- Aggregated patterns derived from any user's content presented as a recommendation or interpretation
- Any indication that we have read, classified, or analysed their writing

8. Operational notes

- The privacy commitments are a Stage 1 requirement, not a Stage 7 polish item. End-to-end encryption is engineered into the Senshin feature from the first commit.

- The privacy policy text is drafted by Tom (with legal review when revenue scales) and signed off by Rieko. The user-facing intro language is in Rieko's voice direction.
- The cost of these commitments is real (engineering complexity, support burden when users lose passwords, exclusion from certain analytics and ML strategies). We accept this cost because the alternative is incompatible with what the app is for.

Confidential. Auwa Limited. All rights reserved.